

DevOps Security: Challenges and 6 Critical Best Practices

What is DevOps Security?

DevOps Security is the convergence of development, operations, and security, also known as [DevSecOps](#) (the term DevSecOps refers to a DevOps organization that is fully integrated with the security organization). It enables organizations to deliver software at high velocity while integrating security into every step of the software development lifecycle (SDLC).

DevOps methodologies make it possible to deliver software faster and more effectively, in small, incremental updates. The process for building and delivering applications is highly automated. Applications often consist of multiple microservices, deployed within containers and running in public or private cloud environments, which provide high scalability and resilience.

However, while DevOps processes, containers and cloud provide significant business benefits, they also make application security much more difficult. Automating application delivery and breaking software into microservices or containers creates a large number of moving parts that need to be monitored and secured. Every instance of each microservice represents an attack surface.

In addition, a modern DevOps environment uses a rich set of tools such as build servers, container orchestrators, code repositories, and image registries—all of which can be compromised by attackers. This huge complexity means that it is not possible to secure applications as an afterthought, at the end of the development process. It is essential to build security into each aspect of the environment and each stage of application development.

DevOps Security Challenges

DevOps involves the adoption of iterative software development, automation, and the use of programmable, declarative infrastructure. DevOps security issues often stem from conflicts between the different goals of developers and security teams. While the developer's goal is to get software into the pipeline as quickly as possible, security teams want to eliminate as many potential security flaws as possible.

Here are a few key challenges facing DevOps that is not fully integrated with security in a DevSecOps model.

DevOps Teams Don't Have Time for Security

Traditionally, development teams had a cultural resistance to security and testing. Developers and operations teams saw security as an interference that caused delays in the development process. This was made worse by pressure from management to release faster and faster.

However, because security fixes are inevitable, testing and fixing security issues at the end of the cycle actually requires much more time and effort. DevOps teams are realizing that by incorporating changes early in the pipeline, they reduce technical debt and actually save time, while improving the security of their applications.

Cloud Security

The fast adoption of cloud computing by DevOps teams creates its own security challenges. Compared to traditional on-premises deployments, the cloud has a wider attack surface and does not have a well-defined network perimeter.

In the cloud, a small misconfiguration or human error can expose critical resources to public networks. This means that traditional assumptions about protecting the network perimeter, and trusting entities within the perimeter, no longer hold.

DevOps Toolsets Can Be Risky

DevOps teams rely on a diverse toolset to automate all aspects of software delivery pipelines. However, many of these tools are open source and might create security concerns. Even if the tools themselves are secure, DevOps teams might not be implementing security best practices—for example, Kubernetes is not secure by default, and requires complex steps to fully harden a container cluster.

Addressing security concerns in the DevOps technology stack requires visibility and observability (understand what is running in the environment and the behavior of each element), vulnerability scanning, and strategies for automatically implementing security controls.

Weak Access Controls

DevOps environments often require controlled privileged access and secret management. Both individuals and computing tools use credentials such as passwords and API access

tokens to gain access to sensitive resources. Poorly managed secrets or weak access controls can allow attackers to compromise these credentials, gain access to DevOps infrastructure, disrupt operations, and steal data.

DevOps Security Best Practices

1. Adopt a DevSecOps Model

To achieve security in DevOps pipelines, it is essential to adopt a full DevSecOps model. Cross-functional collaboration is critical to integrating security across the DevOps lifecycle. This requires a culture in which everyone is responsible for security.

In a DevSecOps environment, security teams help educate developers about secure coding practices, while developers educate security teams in coding practices and details of the technology stack. Security teams should be able to write code and interact with APIs, and developers should be able to automate security tasks. This helps break down the traditional divide between developers and security professionals.

2. Leverage Penetration Testing and Automated Security Testing

Penetration testing is an authorized attempt to exploit vulnerabilities in an organization's infrastructure, to determine if malicious activity is possible and provide steps for preventing it.

As organizations transition to a DevSecOps model, they should run penetration tests of their development environments to identify the main security gaps. Because manual penetration tests can slow down the development process, they are mainly valuable at early stages of the DevSecOps transition.

To fully integrate security into the development process, automated security testing is required to detect defects, vulnerabilities, data breaches and vulnerabilities as they are introduced into development pipelines. These tests should be run as often as possible, providing developers with immediate feedback about security flaws and remediation instructions.

3. Establish Security Policies

Security policies and governance are critical to consistently managing security risks in enterprise environments. You should establish a set of clear and understandable policies and

procedures for access control, configuration management, code reviews, vulnerability testing, and security tools. Developers, operations, and security teams should all align behind these policies and ensure they are implemented across the SDLC.

4. Automate Everything

Many security processes can be automated. This is important to scale and accelerate security operations to keep pace with DevOps processes.

Configuration management, code analysis, vulnerability discovery and remediation, and privileged access management all require automation. Otherwise, it is difficult to identify security flaws early without slowing down the pipeline. Automation also saves time, freeing developers and security teams to focus on more important tasks.

5. Use Vulnerability Management

Deploy a system that can scan, evaluate, and fix vulnerabilities throughout the SDLC and ensure that code is secure prior to deployment. Vulnerabilities don't end there—in testing, staging, and production environments, operations and security teams must continue to run tests to identify vulnerabilities.

Because resources are often immutable (they do not change once running in the environment), vulnerabilities are passed back to development teams, who create a new version of the code, container image, or script and re-deploy it to the environment.

6. Privileged Access Management

Monitoring and controlling access is critical to the security of the DevOps stack itself. Privileged access should be strictly controlled to reduce the potential for supply chain attacks.

For example, you should never use “super user” accounts and be careful to restrict developer and tester access to the specific areas they work on. Provide “just in time” access to mission critical systems, then revoke it. Ensure that your privileged credentials are securely stored, and monitor privileged sessions to check for suspicious activity.

DevOps Security with HackerOne

Modern organizations need a new approach to code review and vulnerability detection that does not slow down the SDLC. HackerOne is able to contribute to the security of DevOps

with human discovery of software vulnerabilities that code scanning tools often miss.

HackerOne harnesses the collective talent of over a million ethical hackers to find the hard to find code flaws. By including HackerOne early in the SDLC, organizations can more rapidly release digital products with greater confidence, knowing that their software applications were vetted by security experts while they were being developed. This approach assures the most effective and efficient use of valuable DevOps teams while increasing the security of the application landscape.

[Learn more about the HackerOne platform](#)

Company

Leadership

Careers

Partners

Newsroom

Contact Us

Knowledge

Center

Application Security

Penetration Testing

Cloud Security

Hacking

Cybersecurity

Attacks

DevSecOps

Resources

Blog

Documentation

Leaderboard

Partner Portal

Resources

Contacted
by a
hacker?

